

AUDIT DE SÉCURITÉ ET TEST D'INTRUSION D'UN RÉSEAU D'ENTREPRISE

EXECUTIVE SUMMARY

Organisation auditée : MyLab (environnement Active Directory « mylab.local », simulé)
par : Kawtar Moutabarrik (Standard)

Encadrée par : Pr. Idrissi
Méthodologie : PTES (Penetration Testing Execution **Réalisée**

1. Contexte et objectif

Ce rapport présente les résultats d'un audit de sécurité et d'un test d'intrusion (pentest) mené selon la méthodologie PTES sur un réseau d'entreprise simulé en environnement de laboratoire. L'exercice avait pour objectif de simuler, de manière contrôlée, une attaque réelle contre l'infrastructure de l'organisation MyLab afin d'identifier les vulnérabilités exploitables avant qu'un attaquant malveillant ne le fasse, de quantifier la surface d'attaque au moyen du référentiel CVSS v3.1, et de mesurer objectivement l'impact des outils offensifs sur les ressources système et réseau des cibles (CPU, RAM, débit) grâce à une chaîne d'instrumentation Prometheus / cAdvisor / pidstat / Grafana.

2. Périmètre audité

- Zone externe (WAN) : poste de l'auditeur (Kali Linux).
- Zone démilitarisée (DMZ) : application Web vulnérable exposée et pile de supervision (Prometheus / Grafana), hébergées sous Docker.
- Zone interne (LAN) : contrôleur de domaine Active Directory sous Windows Server 2019 (domaine mylab.local) et un poste client Windows 10 joint au domaine.

La segmentation réseau entre ces trois zones est assurée par un pare-feu pfSense, dont la politique de filtrage a été progressivement ouverte au cours de l'audit afin de reproduire une progression réaliste d'attaque, d'un accès externe restreint vers une compromission interne complète.

3. Synthèse des résultats

Indicateur	Résultat
Vulnérabilités validées manuellement (DMZ)	4 — 100 % vrais positifs, 0 % faux positifs
Vulnérabilité la plus critique	OS End-of-Life – Debian 9 « Stretch » (CVSS v3.1 : 10.0 – Critique)
Exposition résiduelle LAN / Active Directory (scan automatisé)	1 (ICMP Timestamp Disclosure – CVSS v3.1 : 2.1 – Faible)
Tentatives d'exploitation menées	5
Exploitations réussies	3
Taux d'exploitation (CVE critiques + élevées)	60 %

Niveau de compromission atteint	Compromission totale du contrôleur de domaine (Domain Admin)
---------------------------------	--

4. Chaîne de compromission observée

L'exploitation directe de services distants s'est révélée limitée : la tentative d'exploitation d'EternalBlue (MS17-010) contre le poste Windows 10 a échoué du fait de l'application des correctifs de sécurité, tout comme la tentative contre

Audit de sécurité et test d'intrusion — MyLab | Executive Summary

le service Samba de l'hôte DMZ, protégé par le rejet des authentifications NTLMv1 obsolètes. Ces deux échecs valident la robustesse du patch management sur ces composants.

La compromission s'est en revanche concrétisée par l'exploitation d'une erreur de configuration : l'appartenance du compte d'exploitation au groupe système docker sur l'hôte DMZ a permis, via le montage du système de fichiers hôte dans un conteneur exécuté en root, d'obtenir un accès root complet sur cette machine. Sur le poste Windows 10, la livraison d'une charge utile via un binaire d'administration légitime (technique LOLBin) a permis d'ouvrir une session à privilèges administrateur, puis d'élever ces privilèges jusqu'à NT AUTHORITY\SYSTEM.

À partir de ce point d'ancrage, l'extraction en mémoire des empreintes d'authentification (Mimikatz) a révélé le hash NTLM du compte Administrateur du domaine. Ce hash, validé par une attaque Pass-the-Hash (CrackMapExec, statut « Pwn3d! »), a permis un mouvement latéral direct vers le contrôleur de domaine (impacket-psexec). Une attaque DCSync a ensuite permis d'extraire les secrets du domaine, dont le hash du compte krbtgt, utilisé pour forger un Golden Ticket garantissant un accès persistant et furtif à l'ensemble du domaine. Trois mécanismes de persistance distincts (tâche planifiée, service Windows, clé de registre Run) ont été testés avec succès puis nettoyés, et un scénario d'exfiltration de données a été mené à son terme sans blocage.

5. Impact mesuré sur les ressources (Performance Engineering)

Côté attaquant (Kali Linux), les outils offensifs génèrent un surcoût système net et mesurable : surcharge CPU moyenne de +29,1 % (pic à 85 % lors du scan Nmap) et surconsommation mémoire de 0,52 GiB. À l'inverse, côté cible Windows, les techniques de mouvement latéral et de réplification AD se révèlent remarquablement furtives : la charge processeur reste stable autour de 11,2 % en moyenne (proche du niveau de référence), seule une hausse ponctuelle du débit réseau à 85 kb/s pendant la reconnaissance Nmap constituant un indicateur exploitable par un dispositif de détection (IDS/SOC).

6. Recommandations prioritaires

- P1 — Immédiat : retirer ou migrer le système Debian 9 (End-of-Life) exposé en DMZ (CVSS 10.0) et restreindre l'appartenance au groupe docker aux seuls comptes strictement nécessaires, ce vecteur ayant permis l'élévation root.
- P2 — Court terme : imposer l'attribut HttpOnly/Secure sur les cookies de session et chiffrer les échanges applicatifs (TLS) en DMZ ; superviser en continu les authentifications Pass-the-Hash et les requêtes de réplification DRSUAPI (DCSync) via un SIEM.
- P2 — Court terme : réduire la durée de vie des tickets Kerberos et planifier une rotation régulière du compte krbtgt afin de limiter la fenêtre d'exploitation d'un Golden Ticket.
- P3 — Moyen terme : durcir la pile réseau (désactivation des TCP Timestamps, limitation de l'exposition ICMP) pour réduire la surface de reconnaissance passive.

7. Conclusion

Cet audit a permis de valider, de bout en bout, un scénario d'attaque réaliste conduisant d'une reconnaissance externe à la compromission totale du contrôleur de domaine, avec un taux d'exploitation de 60 % sur les vulnérabilités critiques et élevées identifiées. Les correctifs récents ont efficacement bloqué les vecteurs d'exploitation directe (EternalBlue, Samba), mais une erreur de configuration (groupe docker) et l'absence de contrôles sur les authentifications par hash ont suffi à permettre une prise de contrôle complète et furtive de l'environnement. Le volet Performance Engineering confirme par ailleurs que les techniques de mouvement latéral et de réplication AD laissent une empreinte système minimale sur la cible, renforçant la nécessité d'une détection basée sur le comportement réseau plutôt que sur la seule charge système. Le rapport technique détaillé, incluant le scoring CVSS complet, les preuves de concept et le protocole de mesure, est présenté dans les sections suivantes.